

INFORME DE POLÍTICAS DE SEGURIDAD

CREACIÓN DE POLÍTICAS DE SEGURIDAD DLP

LINEAMIENTOS PARA PROTEGER DATOS CONFIDENCIALES
MEDIANTE CLASIFICACIÓN DE INFORMACIÓN,
CONTROL DE ACCESO, MONITOREO Y PREVENCIÓN
DE FILTRACIONES



EMPRESA:
LOTX (nombre fantasía)

ELABORADO POR:
SANTIAGO GARCÍA

FECHA:
10 DE JULIO DE 2026

1. Introducción Prevención de Pérdida de Datos (DLP)

Data Loss Prevention, o Prevención de Pérdida de Datos, es el conjunto de políticas, procesos y herramientas que una organización utiliza para evitar que su información confidencial sea expuesta, copiada, modificada o compartida sin autorización. DLP no se limita a una herramienta técnica: funciona como una práctica de gobierno de la información que define qué datos se protegen, quién puede acceder a ellos, por qué medios pueden circular y qué controles deben aplicarse cuando existe riesgo de fuga.

Dentro de LOTX, una política DLP permite reducir errores humanos, accesos indebidos, exposición accidental de documentos, uso inadecuado de plataformas colaborativas y posibles acciones maliciosas. Su importancia se relaciona directamente con la protección de datos personales, información interna, documentos comerciales, credenciales, registros financieros y cualquier activo de información que pueda afectar la operación, la reputación o el cumplimiento legal de la organización.

El objetivo de este informe es establecer una base de políticas DLP aplicable a la organización, priorizando el Principio del Menor Privilegio, la clasificación de datos, el monitoreo de actividades sensibles, la prevención de filtraciones y la concientización del personal.

2. Clasificación de Datos

La clasificación de datos permite aplicar controles proporcionales al nivel de sensibilidad de la información. No todos los documentos requieren el mismo nivel de protección; por eso, LOTX utilizará categorías claras para definir accesos, restricciones y responsabilidades.

Categoría	Descripción	Ejemplos	Tratamiento recomendado
Datos públicos	Información aprobada para ser divulgada sin afectar a la organización.	Contenido del sitio web, comunicados públicos, publicaciones institucionales, material promocional.	Puede compartirse externamente si fue aprobado por el área responsable.
Datos internos	Información de uso laboral que no está destinada al público general.	Procedimientos internos, reportes operativos, documentación administrativa, manuales de trabajo.	Acceso limitado a empleados y equipos que lo necesiten para sus funciones.
Datos sensibles	Información confidencial cuya exposición puede generar daño legal, económico, operativo o reputacional.	Datos personales, contratos, nómina, información financiera, credenciales, acuerdos, código fuente, bases de datos.	Acceso restringido, cifrado, monitoreo, aprobación formal y bloqueo de compartición no autorizada.
Datos críticos	Información esencial para la continuidad del negocio o altamente regulada.	Secretos de infraestructura, llaves API, información legal sensible, datos masivos de clientes, respaldos estratégicos.	Controles estrictos, MFA, registro de actividad, revisión frecuente de permisos y respuesta inmediata ante alertas.

La clasificación deberá aplicarse al crear, almacenar o compartir información. Cada área será responsable de identificar sus documentos sensibles y mantenerlos correctamente etiquetados.

3. Acceso y Control

El acceso a la información se gestionará bajo el Principio del Menor Privilegio. Esto significa que cada usuario tendrá únicamente los permisos necesarios para cumplir sus tareas, durante el tiempo necesario y sobre los datos estrictamente relacionados con su función.

- Los accesos a datos internos, sensibles y críticos deberán asignarse por rol, no por solicitud informal entre usuarios.
- Los permisos de edición se limitarán a los responsables directos de cada documento, carpeta, sistema o repositorio.
- Los accesos temporales deberán tener fecha de vencimiento y justificación documentada.
- Los empleados que cambien de área, rol o proyecto deberán pasar por una revisión de permisos.
- Las cuentas inactivas, externas o sin responsable asignado deberán deshabilitarse o revocarse.

Flujo de revisión de permisos

Etapas	Responsable	Acción
Solicitud	Usuario solicitante	Indica qué información necesita, por cuánto tiempo y para qué tarea.
Validación funcional	Supervisor o jefe de área	Confirma si el acceso es necesario para la función del usuario.
Evaluación de riesgo	Seguridad Informática	Revisa la clasificación de los datos y define controles adicionales si corresponde.
Aplicación técnica	TI / Administrador del sistema	Asigna permisos por rol, activa MFA si aplica y registra la autorización.
Revisión periódica	Seguridad Informática + responsables de área	Revisa permisos activos, accesos temporales, usuarios inactivos y excepciones.
Revocación	TI	Retira permisos cuando finaliza la tarea, cambia el rol del usuario o se detecta uso indebido.

Las revisiones ordinarias se realizarán trimestralmente. Para datos críticos, la revisión podrá ser mensual o inmediata ante cambios de personal, incidentes o alertas de seguridad.

4. Monitoreo y Auditoría

El monitoreo tiene como objetivo detectar accesos no autorizados, movimientos anómalos de información, intentos de compartir datos sensibles y cambios indebidos de permisos. La auditoría permite revisar evidencia, comprobar cumplimiento y corregir desviaciones.

Herramienta o control	Uso dentro de la política DLP
Solución DLP	Detecta datos sensibles, aplica reglas de bloqueo, genera alertas y registra eventos de riesgo.
SIEM	Centraliza logs, correlaciona eventos de sistemas, usuarios y aplicaciones, y prioriza incidentes.
IAM / Active Directory	Administra identidades, grupos, roles, accesos y revisiones de permisos.
EDR	Detecta comportamientos anómalos en endpoints, como extracción masiva o ejecución sospechosa.
CASB o seguridad cloud	Controla uso de aplicaciones en la nube, enlaces compartidos, descargas y accesos externos.
Registros de auditoría	Permiten verificar quién accedió a qué datos, cuándo, desde dónde y qué acción realizó.

- Se generarán alertas cuando un usuario intente compartir datos sensibles fuera de la organización.
- Se revisarán accesos masivos, descargas inusuales, cambios de permisos y creación de enlaces públicos.
- Los eventos críticos deberán escalar a Seguridad Informática para análisis y respuesta.
- Las auditorías trimestrales deberán dejar evidencia de hallazgos, responsables y acciones correctivas.

5. Prevención de Filtraciones

La prevención de filtraciones combinará controles técnicos, reglas de uso y medidas de protección sobre la información sensible. La política no busca bloquear el trabajo diario, sino reducir la posibilidad de que los datos salgan por error, negligencia o uso indebido.

- Cifrado de datos sensibles en reposo y en tránsito mediante herramientas corporativas aprobadas.
- Bloqueo o advertencia automática cuando se intente enviar información sensible a destinatarios no autorizados.
- Restricción de enlaces públicos y permisos amplios en plataformas colaborativas.
- Uso obligatorio de MFA para sistemas que almacenan información sensible o crítica.
- Aplicación de etiquetas como Público, Interno, Sensible o Crítico para activar reglas DLP.
- Registro de exportaciones, descargas masivas, copias de bases de datos y cambios de permisos relevantes.

- Proceso formal de excepción cuando una necesidad del negocio requiera compartir datos sensibles con terceros.

Criterio central: si un dato sensible debe compartirse, primero se valida la necesidad, luego se limita el alcance, se protege el contenido y finalmente se deja evidencia de la autorización.

6. Educación y Concientización

Una política DLP solo funciona si el personal entiende qué debe proteger y cómo actuar. La capacitación debe ser práctica, frecuente y vinculada a situaciones reales de trabajo: compartir documentos, enviar correos, usar repositorios, descargar reportes o manejar datos personales.

- Capacitación inicial obligatoria para todo nuevo ingreso sobre clasificación de datos y uso aceptable de información.
- Capacitaciones trimestrales breves con ejemplos de errores comunes y buenas prácticas.
- Guías internas sobre cómo compartir información sensible, solicitar permisos y reportar incidentes.
- Recordatorios periódicos sobre phishing, uso de contraseñas, manejo de documentos y riesgos de compartir datos fuera de la organización.
- Evaluaciones cortas para confirmar comprensión de la política y reforzar puntos débiles.
- Canal claro para reportar pérdida de información, accesos indebidos o dudas sobre clasificación de datos.

7. Conclusión

La creación de políticas de seguridad DLP permite que 4 Geeks proteja su información confidencial de forma ordenada y verificable. Al clasificar los datos, aplicar el Principio del Menor Privilegio, monitorear actividades sensibles, prevenir filtraciones y capacitar al personal, la organización reduce el riesgo de pérdida de datos y mejora su capacidad de respuesta ante incidentes.

Estas políticas deben revisarse de manera continua, ya que los datos, las herramientas y los riesgos cambian con el tiempo. DLP no reemplaza otros controles de seguridad, pero funciona como una capa clave para proteger la información durante todo su ciclo de vida.